

Privilege Escalation Detection and Automated Response – Architecture and Workflow

1. Use Case Overview

This use case demonstrates the detection of privilege escalation activities within a Windows Active Directory environment using Splunk Enterprise and Splunk SOAR.

The solution monitors Windows Security Events associated with security group membership changes. Specifically, the use case focuses on detecting users added to privileged groups such as Domain Admins and Local Administrators.

When privileged group membership changes are detected, Splunk generates an alert and forwards the event to Splunk SOAR. SOAR then performs automated incident response actions including enrichment, tagging, severity assignment, and analyst notification.

2. Business Objective

Privilege escalation is a critical attack technique commonly used by threat actors after initial access has been achieved.

The objective of this use case is to:

- Detect unauthorized privilege escalation activity.
- Identify users added to privileged groups.
- Provide rapid visibility to SOC analysts.
- Automate incident enrichment and triage.
- Reduce incident response time.

3. Solution Components

Data Sources

- Windows Server 2022 Domain Controller
- Windows 11 Domain-Joined Client

Log Collection

- Splunk Universal Forwarder
- Splunk Heavy Forwarder

SIEM Components

- Splunk Search Head
- Splunk Indexer

SOAR Components

- Splunk SOAR 7.1.0.225

Security Events Monitored

Domain Admin Group Changes

- Event ID 4728
- Member added to a security-enabled global group

Local Administrators Group Changes

- Event ID 4732
- Member added to a security-enabled local group

4. Architecture Diagram

Diagram 1: High-Level Architecture

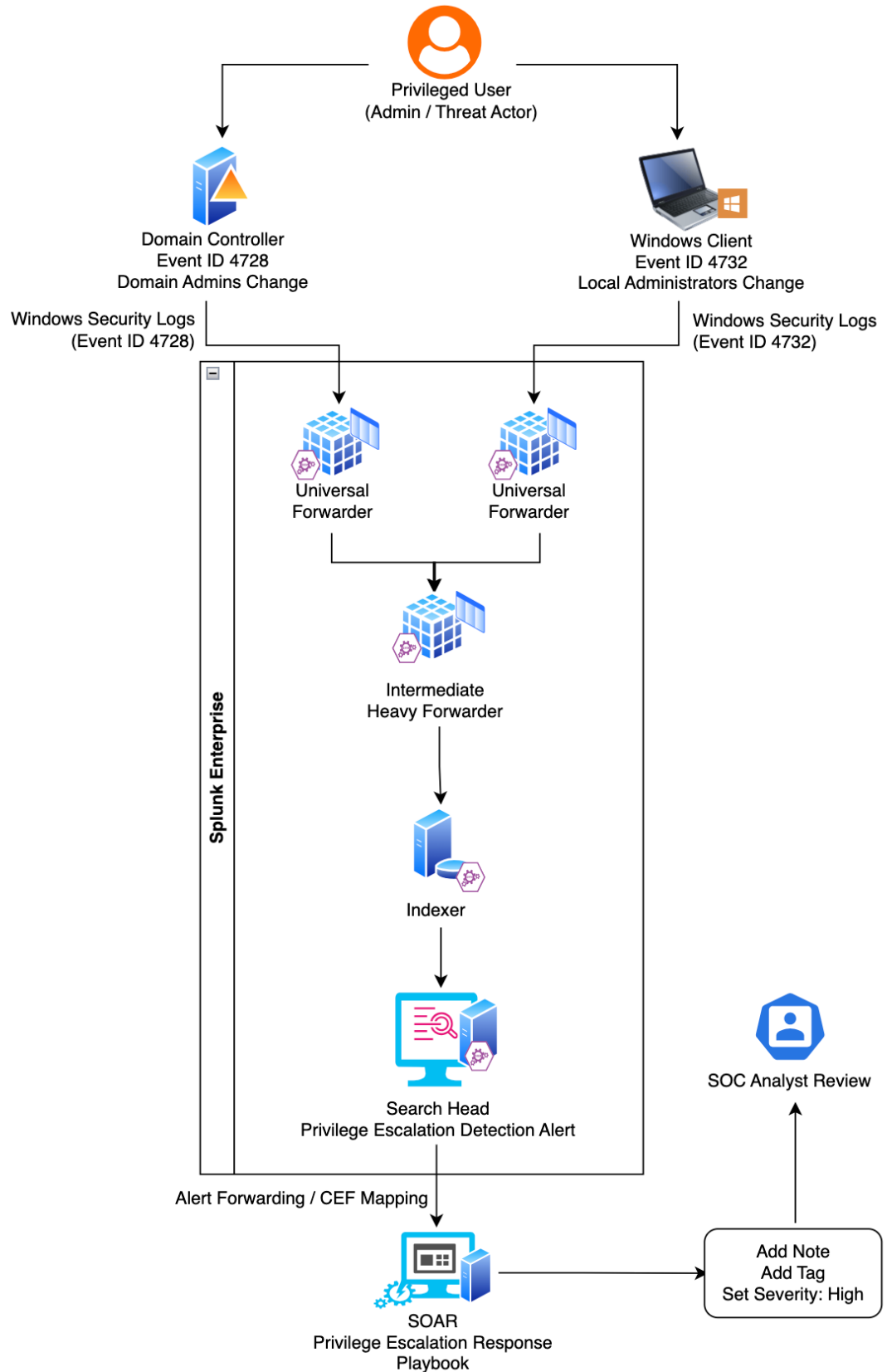
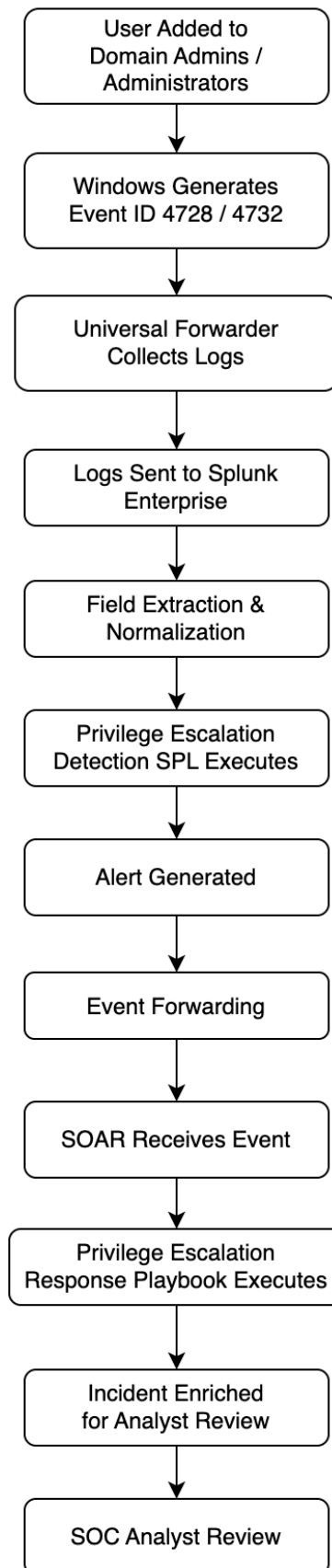


Diagram 2: Detection & Response Workflow



5. Detection Workflow

Step 1 – Privilege Escalation Activity

An administrator or attacker adds a user account to a privileged group.

Examples:

- Domain Admins
- Administrators

Step 2 – Event Generation

Windows records the group membership modification.

Examples:

- Event ID 4728
- Event ID 4732

Step 3 – Log Collection

Windows Security Events are collected by Splunk Universal Forwarders and sent to the Splunk platform.

Step 4 – Detection

Splunk searches identify privileged group membership modifications.

Field extraction and normalization logic are applied to obtain:

- User SID
- Added User
- Actor
- Privileged Group
- Source System

Step 5 – Alert Generation

A Privilege Escalation alert is generated.

Step 6 – Event Forwarding

Alert data is forwarded to Splunk SOAR using the Splunk App for SOAR Export.

Step 7 – Automated Response

The SOAR playbook performs:

- Event filtering
- Severity assignment
- Tag creation
- Analyst note creation

Step 8 – Incident Visibility

The incident is enriched and presented to analysts for investigation.

6. Security Benefits

- Early detection of privilege abuse.
- Increased visibility into privileged access changes.
- Faster analyst triage.
- Automated incident enrichment.
- Improved security monitoring capabilities.

7. Expected Outcome

Upon privileged group membership modification:

- Windows logs the event.
- Splunk detects the activity.
- Alert is forwarded to SOAR.
- Playbook executes automatically.
- Incident severity is assigned.
- Investigation artifacts are created for analysts.

Next Steps

Ensuring that certain prerequisites are met before moving on to simulating Privilege Escalation attack – Refer

22_Prerequisites_Server_Client_before_Implementing_PrivEsc_UseCase_V1.pdf.